

=====

=====

FEDRAMP MODERATE – System Security Plan (SSP)

=====

=====

System : Phoenix-Gov SaaS Platform
Version : 2.0-massive Date : 2025-08-30
Owner : Phoenix Cloud Systems Ltd. | AO: Claire Lin, VP Security
Boundary : AWS GovCloud (us-gov-west-1, us-gov-east-1) + CloudFront + Direct Connect
Attachments: See per control

=====

=====

1. AC-1 Access Control Policy & Procedures

- Phoenix-Gov's Access Control Policy (ACP-2025-AC1) approved by the CISO, updated annually.
 - Procedures documented in Confluence: onboarding/offboarding, least-privilege, break-glass.
- Attachment: AC1-A (ACP-2025-AC1.pdf)

2. AC-2 Account Management

- AWS IAM, AWS SSO, and Okta federated via SAML are authoritative.
 - Automated inactivation: Config rule `phoenix-ac2-inactive` disables after 30 days.
 - Quarterly reviews via AWS Audit Manager, attestation by BU leads.
- Attachments: AC2-A (iam_users_export.csv), AC2-B (inactive_rule.yaml)

3. AC-3 Access Enforcement

- Permission boundaries + SCPs enforce RBAC; Deny-by-default on S3/EBS unless `PrincipalTag/Role=Allowed`.
 - EKS pods use IRSA; each pod uses a unique, least-privilege IAM role.
- Attachment: AC3-A (scp_policies.json)

4. AC-4 Information Flow Enforcement

- VPC peering and Transit Gateway rules restrict cross-account traffic.
 - Security Groups default to deny all; NACLs enforce subnet-level controls.
- Attachment: AC4-A (vpc_peering_rules.txt)

5. AC-5 Separation of Duties

- IAM roles split duties: DevOps vs SecurityAdmin vs Auditor roles.
 - AWS CloudTrail insights flag any cross-role elevation attempts.
- Attachment: AC5-A (cloudtrail_insight_settings.json)

6. AC-6 Least Privilege

- Maximum session duration = 1 hr.
 - Guardrails alert on any `iam:PutRolePolicy` outside emergency process.
- Attachment: AC6-A (guardrails_config.json)

7. AC-7 Unsuccessful Logon Attempts

- AWS SSO lockout: 5 attempts → 15 min lockout.
 - IAM console lockouts monitored via CloudWatch alarms.
- Attachment: AC7-A (sso_lockout_policy.pdf)

8. AC-17 Remote Access

- All remote sessions via SSM Session Manager; no open 22/3389 inbound.
 - AWS Client VPN with MFA and cert-based auth.
- Attachment: AC17-A (ssm_session_logs.csv)

9. AC-19 Access Control for Mobile Devices

- Mobile device management (MDM) via AWS Flare; only AWS-approved devices can access the console.
- Attachment: AC19-A (mdm_device_list.csv)

10. AC-20 Use of External Systems

- No SSH or RDP from public internet; all admin via approved bastion hosts in private subnets.
- Attachment: AC20-A (bastion_inventory.csv)

11. AU-2 Audit Events

- CloudTrail in all GovCloud regions with log validation.
 - VPC Flow & ALB logs → `central-logs` bucket.
 - Macie sensitive-data scans nightly.
- Attachment: AU2-A (trail_status.json)

12. AU-3 Content of Audit Records

- CloudTrail records include userIdentity, eventName, sourceIPAddress, requestParameters, responseElements.
- Attachment: AU3-A (cloudtrail_schema.json)

13. AU-6 Audit Review, Analysis, & Reporting

- GuardDuty findings → Security Hub → Jira via EventBridge.
 - Weekly SOC-Ops calls, minutes in Confluence.
- Attachment: AU6-A (eventbridge_rules.json)

14. AU-8 Time Stamps

- All systems sync to Amazon Time Sync Service via NTP.
- Attachment: AU8-A (ntp_config.txt)

15. AU-12 Log Retention

- S3 Object Lock (GOVERNANCE, 365 days); Glacier Deep Archive after 180 days.
- Attachment: AU12-A (lifecycle_policy.json)

16. CA-2 Security Assessments

- Annual third-party pentests; results stored in AWS Secrets Manager (encrypted).

Attachment: CA2-A (pentest_report.pdf)

17. CA-7 Continuous Monitoring

- AWS Config conformance packs (CIS, PCI, NIST) run hourly.

Attachment: CA7-A (config_conformance_results.csv)

18. CM-2 Baseline Configuration

- Terraform modules approved in CodeArtifact; AMLs built via EC2 Image Builder hardened to CIS L2.

Attachment: CM2-A (terraform_module_registry.csv)

19. CM-3 Configuration Change Control

- All Infra-as-Code changes via GitOps; PR approvals required from Security team.

Attachment: CM3-A (github_branch_policies.md)

20. CM-6 Configuration Settings

- SSM State Manager enforces CIS benchmarks every hour.

Attachment: CM6-A (ssm_state_manager_summary.json)

21. CP-2 Contingency Plan

- Stored in AWS Backup Vault; DR tabletop every 6 months.

Attachment: CP2-A (dr_plan_sop.pdf)

22. CP-4 Contingency Testing

- Last DR failover: 2025-06-10; RTO=25min, RPO=4min.

Attachment: CP4-A (dr_test_report.pdf)

23. CP-7 Alternate Processing Site

- Active-Active Aurora Global DB; Route 53 health checks; automated failover Lambda.

Attachment: CP7-A (aurora_global_status.json)

24. CP-9 System Backup

- AWS Backup protects RDS/DynamoDB/EFS/EC2 nightly; retention=35 days; cross-region copy enabled.

Attachment: CP9-A (backup_job_summary.csv)

25. IA-2 Identification & Authentication

- MFA enforced on all users and root.
- Federation via Okta with WebAuthn.

Attachment: IA2-A (mfa_user_list.csv)

26. IA-5 Authenticator Management

- Password policy: ≥14 chars; rotation=60 days; reuse prevention=5.
- CMK auto-rotation=annual.

Attachment: IA5-A (password_policy.json)

27. IR-2 Incident Response Training

- Annual tabletop + bi-annual phishing simulations; metrics in Security Hub.

Attachment: IR2-A (training_log.csv)

28. IR-4 Incident Handling

- EventBridge rules route GuardDuty → PagerDuty → Incident response runbook.

Attachment: IR4-A (runbook_md.md)

29. IR-6 Incident Reporting

- All incidents P1/P2 reported to FedRAMP PMO within 1 hr via eMASS.

Attachment: IR6-A (emass_upload_log.csv)

30. MA-2 Controlled Maintenance

- Maintenance windows scheduled via Systems Manager; PL-labels enforced.

Attachment: MA2-A (ssm_maintenance_schedule.csv)

31. MP-2 Media Access

- No local storage of PII; backups encrypted; removable media prohibited.

Attachment: MP2-A (media_inventory.txt)

32. MP-4 Media Storage

- S3 buckets with PII tagged; access only via encrypted endpoints.

Attachment: MP4-A (s3_tagging_policy.json)

33. PE-2 Physical Access Authorizations

- GovCloud DC physical controls managed by AWS; SOC1/2 reports available.

Attachment: PE2-A (aws_socaudit_links.txt)

34. PL-2 System & Communications Protection Policy

- Policy SPL-2025-PL2 reviewed annually.

Attachment: PL2-A (SCP_policy.pdf)

35. PM-10 Security Authorization Process

- Continuous authorization tracked in eMASS; artifacts updated monthly.

Attachment: PM10-A (emass_status.csv)

36. PM-11 Mission & Business Impact Analysis

- BIAs conducted annually; results in Confluence.

Attachment: PM11-A (bia_report.pdf)

37. RA-5 Vulnerability Scanning

• Nessus Gov external; Inspector2 internal weekly; critical auto-ticket via Jira.
Attachment: RA5-A (vuln_scan_summary.csv)

38. RA-7 Threat Intelligence

• GuardDuty managed threat lists; Toxic IP feed via AWS Marketplace.
Attachment: RA7-A (threat_list_config.json)

39. SA-11 Developer Security Testing

• Pre-merge: Checkov, tfsec, semgrep.
• ZAP API fuzzing in CodeBuild.
Attachment: SA11-A (pipeline_zap.yml)

40. SA-22 Unsupported System Components

• AWS Security Hub governance checks forbid unsupported AMLs/services.
Attachment: SA22-A (hub_standards_summary.json)

41. SC-7 Boundary Protection

• All ingress via ALB/CloudFront TLS 1.2+; WAF rules block OWASP Top 10.
Attachment: SC7-A (waf_rule_set.json)

42. SC-8 Transmission Confidentiality

• TLS 1.2+ enforced; ALB uses `ELBSecurityPolicy-TLSv1.2-2021-06`.
Attachment: SC8-A (elasticlb_tls_policy.txt)

43. SC-12 Cryptographic Key Establishment

• KMS CMKs generated in Gov regions with HSM; key policies audited quarterly.
Attachment: SC12-A (kms_policies.csv)

44. SC-13 Cryptographic Protection

• Data at rest: S3/RDS/EFS/Dynamo encrypted with CMKs.
• Secrets in Secrets Manager rotated 30 days.
Attachment: SC13-A (encryption_inventory.csv)

45. SC-28 Protection of Information at Rest

• Parameter Store encrypted; rotation every 14 days.
Attachment: SC28-A (param_store_map.json)

46. SI-2 Flaw Remediation

• Patch Manager auto-applies critical patches ≤48 hrs; Inspector2 container scans.
Attachment: SI2-A (patch_status_dashboard.png)

47. SI-4 System Monitoring

• GuardDuty, Detective, Security Hub all ON; custom CloudWatch Contributor Insights.

Attachment: SI4-A (cw_insights_config.json)

48. SI-7 Software, Firmware, & Information Integrity

• CodeSigning enforced for all Lambda/ECR images; Integrity checks in pipeline.
Attachment: SI7-A (codesign_config.yaml)

49. SI-10 Information Input Validation

• API Gateway WAF rules validate JSON schemas; Lambda authorizers sanitise input.
Attachment: SI10-A (waf_json_schema.json)

50. SR-1 Supply Chain Risk Management Policy

• Policy updated Q1 2025; vendor assessments stored in AWS Artifact.
Attachment: SR1-A (supply_chain_assessments.xlsx)

=====
=====
Appendices:

- A – System Inventory CSV
- B – Network Diagrams (PDF)
- C – Data Flow Diagrams (Visio)
- D – Laws & Regulations Mapping
- E – Acronyms & Glossary